Mobile Demo Script Explanation -- Blockchain (Reversing, Challenge 04)

Olawoyin Joseph Pamilerin, ISU520196

In one sentence: The AES key is derived from only 3 bytes of an MD5 digest -- a 2^24 keyspace, not 2^128, so brute force is practical.

Background -- what the terms below mean

What does "Reversing" mean, as a category? A **Reversing** challenge gives you someone else's already-built app (an APK) and asks you to figure out, by reading its code, some secret value it's hiding -- a PIN, a password, a flag string.

What is an APK, and what does "decompile" mean? An APK is the installable file for an Android app. It ships as compiled code that isn't directly readable, so we **decompile** it -- turn it back into readable, Java-like source code -- using a free tool called **jadx** (opened as **jadx-gui**).

Why is there no exploit app to build here? Reversing challenges usually aren't solved by writing an Android app at all -- they're solved by reading the decompiled logic and then writing a small script (usually Python) that re-implements or defeats that same logic on a regular computer, offline.

How the APK was obtained

The target APK was **downloaded directly from the challenge's own page** on challs.reyammer.io, before doing anything else. A copy of it is kept at:

```
C:\Users\Admin\Desktop\MOBISEC Challenge\Challenges\Reversing/04 Blockchain\Original Target APK.apk
```

How the solution was built

No Android app was built for this one at all. It was solved by **decompiling the target with jadx** and then writing a small **Python script** (or, in a couple of cases, working the logic out by hand) that re-implements or defeats the exact same check on a regular computer, offline. The recovered value was then typed directly into the challenge's own flag box.

The vulnerability / technique, in plain terms

The AES key was derived from only 3 bytes of an MD5 digest (2^24 keyspace instead of 2^128). Brute-forced all 16.7M candidates, peeling back 10 rounds of AES-ECB and checking PKCS#5 padding validity at each round.

Files to open

1. Open the target APK in jadx-gui:

```
C:\Users\Admin\Desktop\MOBISEC Challenge\Challenges\Reversing/04 Blockchain\Original Target APK.apk
```

2. FlagChecker.java (jadx decompiled):

```
C:\Users\Admin\Desktop\MOBISEC Challenge\Challenges\Reversing/04 Blockchain\Analysis and Scripts\Reversing/0
```

In jadx-gui's left tree: Source code -> com -> mobisec -> blockchain -> FlagChecker.java

3. solve.py:

```
C:\Users\Admin\Desktop\MOBISEC Challenge\Challenges\Reversing/04 Blockchain\Analysis and Scripts\Reversing/0
```

What to say -- explanation of the exploit, step by step

1. I decompiled the APK and found the AES key was derived from only 3 bytes of an MD5 digest -- a 2^24 keyspace instead of 2^128.

2. I wrote a brute-force script that tried all 16.7 million candidate keys, peeling back 10 rounds of AES-ECB and checking PKCS#5 padding validity at each round to recognize the right key.

3. Once found, I decrypted the ciphertext fully and typed the recovered flag into the flag box.

If an emulator isn't available

If asked how you got/confirmed the flag: "I decompiled the target with jadx, recovered the secret value with a script (no exploit app was built or uploaded for this one), and typed the recovered flag directly into the challenge site's own flag box." There is no APK submission or platform analysis log for this challenge -- don't claim one.

Result

The flag this challenge produced:

```
MOBISEC{blockchain_failed_to_deliver_once_again}
```

Source: Typed into the CTFd flag box; solve confirmed live from /user